

MATERI KULIAH

Pertemuan 11: Kepatuhan & Regulasi

ISO/IEC 27001 • GDPR • UU PDP No.27/2022 • PCI-DSS • HIPAA • Audit Keamanan • Gap Analysis

Mata Kuliah	Keamanan Data	Pertemuan	11 dari 16
Durasi	150 menit (3 SKS)	Metode	Ceramah, Diskusi Kelompok, Studi Kasus
Prasyarat	Pertemuan 1–10 (semua topik keamanan data)	Tugas	Analisis kepatuhan ISO 27001 studi kasus

A. Capaian Pembelajaran Pertemuan

Setelah mengikuti pertemuan ini, mahasiswa diharapkan mampu:

- Menjelaskan konsep kepatuhan (compliance) dan pentingnya regulasi dalam keamanan data
- Memahami struktur, klausul, dan proses sertifikasi ISO/IEC 27001
- Menjelaskan prinsip-prinsip GDPR dan hak-hak subjek data di bawah regulasi Uni Eropa
- Menganalisis kewajiban organisasi berdasarkan UU PDP No. 27 Tahun 2022
- Menjelaskan persyaratan teknis PCI-DSS untuk keamanan data kartu pembayaran
- Melakukan gap analysis sederhana antara kondisi aktual dengan standar keamanan yang berlaku
- Memahami proses dan metodologi audit keamanan informasi

B. Pengantar Kepatuhan (Compliance) & Regulasi

1.1 Mengapa Kepatuhan Penting?

Kepatuhan (compliance) dalam konteks keamanan informasi adalah proses memastikan bahwa organisasi memenuhi persyaratan hukum, regulasi, standar industri, dan kebijakan internal yang berlaku dalam pengelolaan data dan sistem informasi. Kepatuhan bukan sekadar formalitas — melainkan cerminan tanggung jawab organisasi terhadap data yang dipercayakan kepadanya.

Manfaat Kepatuhan	Penjelasan
Perlindungan Hukum	Menghindari sanksi hukum, denda, dan tuntutan pidana akibat pelanggaran regulasi perlindungan data
Kepercayaan Pelanggan	Sertifikasi dan kepatuhan membangun kepercayaan pelanggan bahwa data mereka dikelola dengan bertanggung jawab
Akses Pasar	Beberapa pasar dan pelanggan (khususnya enterprise dan pemerintah) mewajibkan vendor memiliki sertifikasi keamanan tertentu
Efisiensi Operasional	Framework compliance mendorong standarisasi proses dan kontrol keamanan yang meningkatkan efisiensi
Deteksi Risiko Lebih Awal	Proses audit kepatuhan secara berkala membantu mengidentifikasi celah keamanan sebelum dieksploitasi
Competitive Advantage	ISO 27001 dan PCI-DSS menjadi diferensiator kompetitif yang membuka peluang bisnis lebih besar

1.2 Hierarki Regulasi & Standar

Tingkat	Jenis	Contoh
Hukum / Undang-Undang	Kewajiban hukum yang mengikat, ada sanksi pidana/perdata	UU PDP No.27/2022 (Indonesia), GDPR (UE), PDPA (Singapura/Thailand)
Regulasi Sektoral	Aturan khusus untuk industri tertentu oleh otoritas regulasi	OJK (keuangan), Kemenkes (kesehatan), Kominfo (telekomunikasi)
Standar Internasional	Panduan best practice yang diakui global, bersifat sukarela	ISO/IEC 27001, ISO 31000, NIST Cybersecurity Framework
Standar Industri	Persyaratan teknis yang ditetapkan konsorsium industri	PCI-DSS (kartu pembayaran), SWIFT CSP (perbankan), HIPAA (kesehatan AS)
Kebijakan Internal	Aturan dan prosedur yang ditetapkan oleh organisasi sendiri	Security Policy, Acceptable Use Policy, Password Policy

C. ISO/IEC 27001 — Information Security Management System (ISMS)

2.1 Tentang ISO/IEC 27001

ISO/IEC 27001 adalah standar internasional yang menetapkan persyaratan untuk menetapkan, menerapkan, memelihara, dan terus meningkatkan Sistem Manajemen Keamanan Informasi (ISMS — Information Security Management System). Standar ini diterbitkan oleh ISO (International Organization for Standardization) dan IEC, dengan versi terbaru adalah ISO/IEC 27001:2022.



ISO 27001 adalah standar keamanan informasi yang paling banyak diadopsi di dunia. Per 2023, terdapat lebih dari 70.000 organisasi bersertifikasi di lebih dari 150 negara. Di Indonesia, sertifikasi ini semakin diwajibkan untuk penyelenggara sistem elektronik strategis dan perbankan.

2.2 Struktur ISO/IEC 27001:2022 — High Level Structure (HLS)

Klausul	Judul	Isi Utama
4	Konteks Organisasi	Memahami organisasi & konteksnya, kebutuhan pihak yang berkepentingan, ruang lingkup ISMS
5	Kepemimpinan	Komitmen manajemen puncak, kebijakan keamanan informasi, peran & tanggung jawab
6	Perencanaan	Penanganan risiko & peluang, tujuan keamanan informasi & rencana pencapaiannya, perencanaan perubahan
7	Dukungan	Sumber daya, kompetensi SDM, kesadaran, komunikasi, dokumentasi & pengendalian informasi terdokumentasi
8	Operasional	Perencanaan & pengendalian operasional, penilaian risiko keamanan informasi, perlakuan risiko
9	Evaluasi Kinerja	Pemantauan, pengukuran, analisis & evaluasi, audit internal, tinjauan manajemen
10	Peningkatan	Ketidaksesuaian & tindakan korektif, peningkatan berkelanjutan

2.3 Annex A — Kontrol Keamanan ISO 27001:2022

ISO 27001:2022 memiliki Annex A yang berisi 93 kontrol keamanan yang diorganisir ke dalam 4 tema (berbeda dari versi 2013 yang memiliki 114 kontrol dalam 14 domain):

Kode	Tema Kontrol	Jumlah Kontrol	Contoh Kontrol
5	Organizational Controls (Kontrol Organisasional)	37 kontrol	Kebijakan keamanan informasi, manajemen aset, kontrol akses logis, hubungan dengan supplier
6	People Controls (Kontrol SDM)	8 kontrol	Screening karyawan, pelatihan kesadaran, tanggung jawab setelah pemutusan hubungan kerja
7	Physical Controls (Kontrol Fisik)	14 kontrol	Keamanan area, kontrol masuk fisik, pengamanan peralatan, clear desk & clear screen policy
8	Technological Controls (Kontrol Teknologi)	34 kontrol	Manajemen endpoint, proteksi malware, enkripsi, logging, manajemen kerentanan, backup

2.4 Proses Sertifikasi ISO 27001

#	Tahap	Aktivitas	Durasi Tipikal
1	Gap Analysis	Bandingkan kondisi keamanan saat ini vs persyaratan ISO 27001. Identifikasi area yang perlu ditingkatkan.	1–2 bulan
2	Persiapan & Implementasi	Buat kebijakan, prosedur, dan kontrol yang diperlukan. Latih karyawan, jalankan risk assessment.	3–12 bulan
3	Internal Audit	Lakukan audit internal untuk memverifikasi ISMS sudah diimplementasikan sesuai standar.	1–2 bulan
4	Management Review	Manajemen puncak meninjau kinerja ISMS, memutuskan perbaikan yang diperlukan.	2–4 minggu
5	Audit Sertifikasi Thn 1 (Stage 1)	Auditor eksternal memeriksa dokumentasi dan kesiapan ISMS. Tidak ada audit on-site yang intensif.	1–3 hari
6	Audit Sertifikasi Thn 1 (Stage 2)	Audit mendalam on-site: wawancara karyawan, verifikasi implementasi kontrol, review bukti.	2–5 hari
7	Sertifikasi Diterbitkan	Jika lulus, sertifikat ISO 27001 diterbitkan. Berlaku 3 tahun dengan surveillance audit tahunan.	3 tahun
8	Surveillance Audit	Audit tahunan (Tahun 2 & 3) untuk memverifikasi ISMS tetap berjalan dan terus ditingkatkan.	Tiap tahun

2.5 Siklus PDCA dalam ISO 27001

 Plan-Do-Check-Act	PLAN: Tetapkan ruang lingkup ISMS, lakukan risk assessment, tentukan kontrol yang diperlukan (Klausul 4–6) DO: Implementasikan kontrol, latih karyawan, jalankan prosedur operasional (Klausul 7–8) CHECK: Monitor kinerja, lakukan audit internal, ukur efektivitas kontrol (Klausul 9) ACT: Ambil tindakan korektif, perbaiki ketidaksesuaian, tingkatkan ISMS secara berkelanjutan (Klausul 10)
---	---

D. GDPR — General Data Protection Regulation (Uni Eropa)

3.1 Tentang GDPR

GDPR adalah regulasi perlindungan data Uni Eropa yang mulai berlaku pada 25 Mei 2018. GDPR menggantikan Directive 95/46/EC dan menjadi standar perlindungan data paling ketat di dunia. GDPR berlaku tidak hanya untuk organisasi di UE, tetapi juga organisasi di luar UE yang memproses data warga negara UE (termasuk perusahaan Indonesia yang melayani pengguna di Eropa).

 Sanksi GDPR	Pelanggaran GDPR dapat dikenakan denda hingga: • Tier 1: €10 juta atau 2% dari omzet global tahunan (mana yang lebih besar) — untuk pelanggaran prosedural • Tier 2: €20 juta atau 4% dari omzet global tahunan (mana yang lebih besar) — untuk pelanggaran prinsip utama Contoh denda nyata: Amazon €746 juta (2021), Meta €1,2 miliar (2023), Google €50 juta (2019)
---	---

3.2 Tujuh Prinsip GDPR

#	Prinsip	Penjelasan
1	Lawfulness, Fairness & Transparency	Data harus diproses secara sah (ada dasar hukum), adil, dan transparan terhadap subjek data. Organisasi harus memberitahu subjek data tentang bagaimana data mereka digunakan.
2	Purpose Limitation	Data hanya boleh dikumpulkan untuk tujuan yang spesifik, eksplisit, dan sah. Data tidak boleh diproses lebih lanjut untuk tujuan yang tidak kompatibel dengan tujuan awal.
3	Data Minimisation	Hanya kumpulkan data yang benar-benar diperlukan (adequate, relevant, and limited to what is necessary). Jangan kumpulkan data yang tidak dibutuhkan.
4	Accuracy	Data harus akurat dan diperbarui jika diperlukan. Organisasi harus mengambil langkah untuk memastikan data yang tidak akurat dihapus atau dikoreksi segera.
5	Storage Limitation	Data tidak boleh disimpan lebih lama dari yang diperlukan untuk tujuan pemrosesan. Tetapkan kebijakan retensi data yang jelas.
6	Integrity & Confidentiality	Data harus diproses dengan keamanan yang memadai: perlindungan dari pemrosesan tidak sah, akses ilegal, kehilangan, kerusakan, atau penghancuran.
7	Accountability	Pengendali data (data controller) bertanggung jawab atas kepatuhan GDPR dan harus mampu membuktikannya (dokumentasi, catatan pemrosesan, DPO, DPIA).

3.3 Hak-Hak Subjek Data di Bawah GDPR

Hak Subjek Data	Isi Hak	Kewajiban Organisasi
-----------------	---------	----------------------

Hak Mendapat Informasi (Right to be Informed)	Mengetahui identitas pengendali data, tujuan pemrosesan, penerima data, dan hak-hak yang dimiliki	Berikan privacy notice yang jelas saat mengumpulkan data
Hak Akses (Right of Access)	Mendapat salinan data pribadi yang diproses dan informasi tentang pemrosesannya	Tanggapi permintaan akses dalam 30 hari, tanpa biaya
Hak Koreksi (Right to Rectification)	Meminta koreksi data yang tidak akurat atau melengkapi data yang tidak lengkap	Koreksi data dalam 30 hari, beritahu pihak ketiga jika data sudah dibagikan
Hak Hapus (Right to Erasure / Right to be Forgotten)	Meminta penghapusan data pribadi dalam kondisi tertentu (tidak lagi diperlukan, cabut consent)	Hapus data jika syarat terpenuhi, kecuali ada dasar hukum untuk mempertahankan
Hak Batasi Pemrosesan (Right to Restrict Processing)	Membatasi cara organisasi menggunakan data pribadi mereka sementara keberatan sedang ditinjau	Tandai data sebagai 'restricted', hanya proses untuk tujuan terbatas
Hak Portabilitas (Right to Data Portability)	Menerima data pribadi dalam format terstruktur dan dapat dibaca mesin, serta memindahkannya ke penyedia lain	Sediakan data dalam format interoperable (JSON, CSV, XML)
Hak Keberatan (Right to Object)	Menolak pemrosesan data untuk tujuan pemasaran langsung atau pemrosesan berbasis kepentingan sah	Hentikan pemrosesan segera saat keberatan terhadap direct marketing diterima
Hak atas Keputusan Otomatis (Rights re: Automated Decision-Making)	Tidak menjadi subjek keputusan yang diambil sepenuhnya secara otomatis yang berdampak signifikan	Sediakan intervensi manusia untuk keputusan penting berbasis profiling

3.4 Kewajiban Utama Organisasi di Bawah GDPR

- Data Protection Officer (DPO): Wajib ditunjuk oleh otoritas publik, organisasi yang memproses data skala besar, atau yang memproses data sensitif secara reguler
- Data Protection Impact Assessment (DPIA): Wajib dilakukan sebelum memulai pemrosesan yang berisiko tinggi terhadap hak dan kebebasan individu
- Records of Processing Activities (RoPA): Dokumentasikan semua aktivitas pemrosesan data, termasuk tujuan, dasar hukum, retensi, dan langkah keamanan
- Breach Notification: Wajib melaporkan pelanggaran data kepada otoritas supervisor dalam 72 jam jika berpotensi berisiko bagi hak individu
- Privacy by Design & Default: Keamanan dan privasi harus menjadi pertimbangan sejak awal desain sistem, bukan ditambahkan belakangan

E. UU PDP No. 27 Tahun 2022 — Indonesia

4.1 Latar Belakang & Sejarah

Undang-Undang Perlindungan Data Pribadi (UU PDP) Nomor 27 Tahun 2022 disahkan pada 17 Oktober 2022 dan mulai berlaku penuh setelah masa transisi 2 tahun (berlaku efektif penuh Oktober 2024). UU ini adalah landasan hukum perlindungan data pribadi pertama yang komprehensif di Indonesia, menggantikan berbagai ketentuan yang tersebar di lebih dari 30 regulasi sektoral sebelumnya.



UU PDP merupakan terobosan hukum penting bagi Indonesia. Sebelumnya, perlindungan data tersebar di lebih dari 30 peraturan berbeda seperti UU ITE, PP PSTE, dan peraturan OJK. UU PDP menyatukan semua dalam satu kerangka hukum yang komprehensif dan selaras dengan standar internasional.

4.2 Jenis Data Pribadi dalam UU PDP

Kategori	Contoh Data
Data Pribadi Umum	Nama, alamat, tanggal lahir, nomor telepon, email, jenis kelamin, kewarganegaraan
Data Pribadi Spesifik (Sensitif — perlindungan lebih ketat)	Data kesehatan & medis, data biometrik (sidik jari, retina, wajah), data genetika, pandangan politik, keyakinan agama/kepercayaan, data keuangan, data anak, data kejahatan

4.3 Subjek Hukum dalam UU PDP

Pihak	Definisi	Kewajiban / Hak Utama
Subjek Data Pribadi	Orang perseorangan yang data pribadinya diproses. Pemilik data.	Hak akses, koreksi, hapus, tarik consent, penolakan pemrosesan, portabilitas, keberatan profiling otomatis
Pengendali Data Pribadi (Data Controller)	Pihak yang menentukan tujuan dan cara pemrosesan data pribadi (biasanya organisasi/perusahaan).	Memiliki dasar hukum pemrosesan, melindungi data, notifikasi kebocoran 14 × 24 jam, menunjuk DPO
Prosesor Data Pribadi (Data Processor)	Pihak yang memproses data atas instruksi pengendali (contoh: vendor cloud, firma audit).	Hanya proses sesuai instruksi pengendali, jaga kerahasiaan, laporkan insiden ke pengendali

4.4 Hak Subjek Data dalam UU PDP

- Hak informasi: Mengetahui identitas pengendali, tujuan, dan dasar hukum pemrosesan data
- Hak akses & salinan: Mendapatkan akses dan salinan data pribadi yang diproses
- Hak koreksi & pembaruan: Meminta perbaikan data yang tidak akurat atau tidak lengkap
- Hak penghapusan: Meminta penghapusan data yang tidak relevan atau telah habis masa retensinya
- Hak penarikan persetujuan: Mencabut consent yang telah diberikan sebelumnya
- Hak keberatan: Menolak pemrosesan untuk tujuan tertentu termasuk profiling dan pemasaran
- Hak portabilitas: Mendapatkan data dalam format yang dapat dibaca mesin
- Hak menunda/membatasi: Meminta penundaan pemrosesan dalam kondisi tertentu

4.5 Kewajiban Pengendali Data & Sanksi

Kewajiban Utama	Detail
Dasar Hukum Pemrosesan	Wajib memiliki dasar hukum yang sah: persetujuan (consent), kewajiban kontraktual, kewajiban hukum, kepentingan vital, kepentingan publik, atau kepentingan sah
Persetujuan yang Sah	Consent harus: eksplisit & bebas (tidak dipaksa), spesifik (tujuan jelas), terinformasi (subjek tahu apa yang disetujui), dapat ditarik kapan saja

Notifikasi Kebocoran Data	Wajib memberitahu Komisi PDP dan subjek data dalam 14 × 24 jam (14 hari) setelah kebocoran terdeteksi
Perlindungan Data Anak	Pemrosesan data anak (< 18 tahun) wajib mendapat consent dari orang tua/wali yang sah
Transfer Data ke Luar Negeri	Hanya boleh ke negara yang memiliki perlindungan data setara atau dengan safeguard yang memadai
Rekam Jejak Pemrosesan	Wajib menyimpan catatan aktivitas pemrosesan data yang dapat diperiksa oleh Komisi PDP

Jenis Pelanggaran	Sanksi Maksimum
Pemrosesan data tidak sah yang menyebabkan kerugian	Pidana penjara 5 tahun & denda Rp 5 miliar
Kebocoran data pribadi spesifik (sensitif)	Pidana penjara 5 tahun & denda Rp 5 miliar
Pemalsuan data pribadi yang merugikan orang lain	Pidana penjara 6 tahun & denda Rp 6 miliar
Penggunaan data pribadi yang tidak sesuai tujuan	Pidana penjara 4 tahun & denda Rp 4 miliar
Sanksi administratif untuk badan usaha	Hingga 2% dari pendapatan tahunan

4.6 Perbandingan UU PDP vs GDPR

Aspek	UU PDP Indonesia	GDPR (Uni Eropa)
Berlaku Efektif	Oktober 2024 (setelah masa transisi 2 tahun)	Mei 2018
Otoritas Pengawas	Komisi PDP (dibentuk setelah UU berlaku)	Data Protection Authorities (per negara UE)
Notifikasi Breach	14 × 24 jam (14 hari)	72 jam
DPO	Tidak diwajibkan secara eksplisit (dalam pembahasan)	Wajib untuk kondisi tertentu
DPIA	Tidak disebutkan eksplisit	Wajib untuk pemrosesan berisiko tinggi
Sanksi Maksimum	2% pendapatan tahunan (administratif) + pidana	4% omzet global tahunan
Transfer Data	Ke negara dengan perlindungan setara / safeguard memadai	Idem — adequacy decision atau SCCs

F. PCI-DSS — Payment Card Industry Data Security Standard

5.1 Tentang PCI-DSS

PCI-DSS adalah standar keamanan yang ditetapkan oleh PCI Security Standards Council (didirikan oleh Visa, Mastercard, American Express, Discover, dan JCB) untuk semua organisasi yang menyimpan, memproses, atau mentransmisikan data kartu pembayaran. Versi terbaru adalah PCI DSS v4.0 (berlaku penuh Maret 2025).

 Siapa Wajib?	PCI-DSS wajib diterapkan oleh SEMUA entitas yang bersentuhan dengan data kartu: • Merchant / toko online yang menerima pembayaran kartu • Payment gateway dan payment processor • Acquiring bank (bank penerima) • Vendor software yang memproses transaksi kartu • Provider hosting yang menyimpan data pemegang kartu
--	--

5.2 Enam Tujuan & 12 Persyaratan PCI-DSS

Tujuan PCI-DSS	Req	Persyaratan
Membangun & Memelihara Jaringan Aman	1	Install dan kelola firewall untuk melindungi Cardholder Data Environment (CDE)
	2	Jangan gunakan default vendor untuk password dan parameter keamanan sistem
Melindungi Data Pemegang Kartu	3	Lindungi data pemegang kartu yang tersimpan (enkripsi, masking, tokenisasi)
	4	Enkripsi transmisi data pemegang kartu di jaringan publik terbuka (TLS)
Kelola Program Manajemen Kerentanan	5	Lindungi semua sistem dari malware, perbarui antivirus secara berkala
	6	Kembangkan dan pelihara sistem dan aplikasi yang aman (patch management, SDLC aman)
Terapkan Kontrol Akses Kuat	7	Batasi akses ke data pemegang kartu berdasarkan kebutuhan bisnis (need-to-know)
	8	Identifikasi dan autentikasi akses ke komponen sistem (MFA, ID unik per pengguna)
	9	Batasi akses fisik ke data pemegang kartu
Monitor & Uji Jaringan Secara Reguler	10	Log dan pantau semua akses ke sumber daya jaringan dan data pemegang kartu
	11	Uji sistem dan proses keamanan secara berkala (VA, pentest, IDS/IPS monitoring)
Kelola Kebijakan Keamanan Informasi	12	Pertahankan kebijakan keamanan informasi untuk semua personel

5.3 Level Merchant PCI-DSS & Persyaratan Validasi

Level	Volume Transaksi/Tahun	Persyaratan Validasi	Metode Audit
1	> 6 juta transaksi Visa/MC, atau pernah mengalami breach	Annual Report on Compliance (RoC) oleh QSA bersertifikat + Quarterly Network Scan	Audit oleh Qualified Security Assessor (QSA) eksternal

2	1–6 juta transaksi/tahun	Annual Self-Assessment Questionnaire (SAQ) + Quarterly Network Scan	SAQ internal divalidasi QSA / ISA
3	20.000–1 juta transaksi e-commerce/tahun	Annual SAQ + Quarterly Network Scan oleh Approved Scanning Vendor (ASV)	SAQ internal
4	< 20.000 transaksi e-commerce / < 1 juta transaksi lainnya	Annual SAQ (disarankan) + Quarterly Scan (disarankan)	SAQ internal (mandatori tergantung acquiring bank)

G. HIPAA — Health Insurance Portability and Accountability Act (AS)

6.1 Tentang HIPAA

HIPAA adalah undang-undang federal Amerika Serikat yang mengatur perlindungan informasi kesehatan yang dapat diidentifikasi secara individual (Protected Health Information / PHI). Berlaku untuk covered entities (penyedia layanan kesehatan, health plan, healthcare clearinghouse) dan business associates mereka. Relevan bagi perusahaan Indonesia yang menyediakan layanan digital kesehatan kepada pasien/klien di AS.

Aturan HIPAA	Isi Utama
Privacy Rule	Menetapkan standar nasional untuk melindungi PHI. Mengatur kapan PHI boleh digunakan dan diungkapkan. Memberikan hak kepada pasien atas data kesehatannya.
Security Rule	Menetapkan standar untuk melindungi ePHI (electronic PHI). Tiga jenis safeguard: Administrative (kebijakan, pelatihan), Physical (akses fisik, workstation), Technical (enkripsi, audit log, kontrol akses).
Breach Notification Rule	Wajib memberitahu individu yang terdampak, HHS (Department of Health & Human Services), dan media (jika > 500 orang) dalam 60 hari setelah menemukan pelanggaran.
Enforcement Rule	Menetapkan prosedur investigasi dan denda. Denda: \$100–\$50.000 per pelanggaran, maksimum \$1,9 juta per kategori per tahun. Pelanggaran disengaja: sanksi pidana.

H. Perbandingan Regulasi Keamanan Data

Aspek	ISO 27001	GDPR	UU PDP	PCI-DSS	HIPAA
Wilayah	Global	Uni Eropa	Indonesia	Global	AS
Fokus	Sistem manaj. keamanan info	Privasi data warga UE	Privasi data warga RI	Keamanan data kartu	Data kesehatan
Sifat	Sukarela (bisa disertifikasi)	Wajib hukum	Wajib hukum	Wajib (standar industri)	Wajib hukum
Audit	Audit internal + sertifikasi eksternal	Investigasi DPA	Komisi PDP	QSA Audit / SAQ	HHS OCR Audit

Sanksi Max	Tidak ada sanksi langsung	4% omzet global	2% pendapatan + pidana	Denda per pelanggaran	USD 1,9 juta/tahun
Notifikasi Breach	Tidak ada syarat spesifik	72 jam	14 × 24 jam	Segera ke card brands	60 hari
Update Terbaru	2022	2018 (masih berlaku)	2022 (efektif 2024)	v4.0 (2022)	1996 (diperbarui)

I. Audit Keamanan Informasi

7.1 Definisi & Tujuan Audit

Audit keamanan informasi adalah pemeriksaan sistematis dan independen terhadap kebijakan, prosedur, kontrol, dan praktik keamanan informasi suatu organisasi untuk menilai sejauh mana kontrol keamanan yang ada sudah memadai, efektif, dan sesuai dengan standar atau regulasi yang berlaku.

7.2 Jenis Audit Keamanan

Jenis Audit	Deskripsi	Contoh
Compliance Audit	Memverifikasi apakah organisasi memenuhi persyaratan regulasi, standar, atau kebijakan internal yang berlaku	Audit ISO 27001, audit PCI-DSS, audit UU PDP
Technical Security Audit	Menilai keamanan teknis: konfigurasi sistem, patch level, kontrol akses, enkripsi, dan infrastruktur keamanan	Vulnerability Assessment, konfigurasi review firewall/server
Operational Security Audit	Menilai efektivitas prosedur dan proses operasional keamanan: incident response, change management, access review	Review prosedur IR, password policy, user access review
Financial IT Audit (IT General Controls)	Memastikan sistem TI yang mendukung laporan keuangan memiliki kontrol yang memadai untuk mencegah kecurangan	Audit SOX (Sarbanes-Oxley), audit BPK untuk lembaga pemerintah
Internal Audit	Dilakukan oleh tim internal organisasi. Membantu identifikasi kelemahan sebelum audit eksternal.	ISO 27001 internal audit, quarterly security review
External Audit (Independent Audit)	Dilakukan oleh pihak ketiga yang independen untuk memberikan penilaian objektif kepada stakeholder eksternal	ISO 27001 certification audit, PCI-DSS QSA assessment

7.3 Proses Audit Keamanan (6 Fase)

#	Fase	Aktivitas	Output
1	Perencanaan Audit (Planning)	Tetapkan ruang lingkup, tujuan, jadwal, dan metodologi audit. Tentukan standar acuan. Susun audit plan dan checklist.	Audit Plan, Audit Checklist

2	Pengumpulan Informasi (Fieldwork Preparation)	Kumpulkan dokumentasi: kebijakan, prosedur, diagram jaringan, log, konfigurasi sistem. Wawancara staf kunci.	Evidence list, Interview notes
3	Pengujian Kontrol (Control Testing)	Uji efektivitas kontrol: observasi, inspeksi fisik, uji teknis (konfigurasi, akses), review log dan dokumen.	Test results, Control matrix
4	Analisis Temuan (Finding Analysis)	Identifikasi gap dan kelemahan. Klasifikasikan temuan berdasarkan tingkat risiko (Critical/High/Medium/Low). Verifikasi dengan auditee.	Draft findings
5	Pelaporan (Reporting)	Susun laporan audit lengkap: executive summary, temuan detail, bukti, rekomendasi perbaikan, dan timeline tindak lanjut.	Audit Report
6	Tindak Lanjut (Follow-up)	Pantau implementasi rekomendasi perbaikan oleh auditee. Verifikasi bahwa temuan telah ditindaklanjuti sesuai komitmen.	Corrective Action Plan status

J. Gap Analysis Keamanan Informasi

8.1 Definisi & Tujuan

Gap Analysis adalah proses membandingkan kondisi keamanan informasi organisasi saat ini (as-is state) dengan kondisi yang diinginkan berdasarkan standar atau regulasi tertentu (to-be state). Hasil gap analysis menjadi roadmap prioritas implementasi keamanan.

8.2 Metodologi Gap Analysis

#	Langkah	Aktivitas	Tools / Output
1	Tentukan Standar Acuan	Pilih standar yang relevan: ISO 27001, PCI-DSS, NIST CSF, atau regulasi yang wajib dipenuhi	ISO 27001 Annex A Checklist
2	Inventarisasi Kontrol Saat Ini	Dokumentasikan semua kontrol keamanan yang sudah ada: kebijakan, prosedur, teknologi, dan SDM	Asset register, Policy inventory
3	Penilaian Tingkat Kematangan	Nilai setiap kontrol: 0=Tidak Ada, 1=Ad-hoc, 2=Terdefinisi, 3=Terkelola, 4=Teroptimasi (CMM scale)	Maturity scorecard
4	Identifikasi Gap	Bandingkan kondisi saat ini vs persyaratan standar. Tandai area yang belum dipenuhi atau belum memadai	Gap matrix
5	Prioritaskan Remediasi	Prioritaskan perbaikan berdasarkan tingkat risiko, kompleksitas implementasi, dan biaya	Risk-prioritized roadmap
6	Buat Remediation Plan	Rancang rencana tindak lanjut: aktivitas, PIC, sumber daya, target tanggal, dan ukuran keberhasilan	Remediation Plan / roadmap

8.3 Contoh Gap Analysis ISO 27001 — Studi Kasus Perusahaan Fintech

Skenario: Perusahaan fintech dengan 50 karyawan sedang mempersiapkan sertifikasi ISO 27001. Berikut hasil gap analysis parsial terhadap beberapa kontrol Annex A:

ID	Kontrol ISO 27001	Kondisi Saat Ini	Target	Gap Level	Rekomendasi Tindak Lanjut
5.1	Kebijakan keamanan informasi	Ada — tidak pernah diperbarui (3 tahun)	Matang (4)	TINGGI	Update kebijakan, review tahunan, sosialisasi
5.15	Kontrol akses (policy)	Tidak terdokumentasi	Matang (4)	KRITIS	Buat access control policy, implementasi RBAC
6.1	Screening karyawan baru	Cek referensi saja, belum ada background check	Matang (3)	SEDANG	Tambah background check untuk posisi sensitif
7.2	Pelatihan keamanan informasi	Belum ada program pelatihan formal	Matang (3)	TINGGI	Buat program security awareness annual
8.7	Perlindungan dari malware	Antivirus di semua endpoint, update otomatis	Matang (4)	RENDAH	Tambah EDR solution, review konfigurasi
8.13	Backup informasi	Backup harian ada, belum pernah diuji	Matang (4)	TINGGI	Jadwal uji restore bulanan, enkripsi backup
8.24	Penggunaan kriptografi	TLS di web app, password di-hash MD5	Matang (4)	KRITIS	Migrasi ke bcrypt, audit seluruh penggunaan crypto
8.28	Secure coding	Tidak ada SDLC security, tidak ada code review	Matang (3)	KRITIS	Implementasi SSDLC, wajibkan security code review

K. Ringkasan Konsep Kunci

Regulasi / Konsep	Poin Kunci yang Wajib Diingat
ISO 27001	ISMS framework berbasis PDCA. 93 kontrol dalam 4 tema. Klausul 4–10. Sertifikasi 3 tahun + annual surveillance audit
GDPR	7 prinsip perlindungan data. 8 hak subjek data. Denda hingga 4% omzet global. Breach notification 72 jam. DPO wajib untuk kondisi tertentu
UU PDP	Berlaku efektif Oktober 2024. Data sensitif butuh perlindungan lebih. Breach notification 14×24 jam. Sanksi hingga 2% pendapatan + pidana
PCI-DSS	Wajib untuk semua yang menyentuh data kartu. 12 persyaratan dalam 6 tujuan. Versi terbaru v4.0. Level 1 butuh QSA eksternal

HIPAA	Perlindungan PHI di sektor kesehatan AS. Privacy Rule + Security Rule + Breach Notification Rule. Berlaku juga untuk business associates
Audit	Compliance Audit vs Technical Audit vs Operational Audit. 6 fase: Plan-Fieldwork-Testing-Analysis-Report-Follow-up
Gap Analysis	Bandingkan as-is vs to-be. Skala kematangan 0–4 (CMM). Output: prioritized remediation roadmap

L. Latihan & Tugas

Soal Diskusi (In-Class)

- Sebuah startup e-commerce Indonesia memiliki pelanggan di Indonesia dan beberapa negara UE. Regulasi keamanan data apa saja yang wajib dipenuhi? Jelaskan kewajiban spesifik yang berlaku dari masing-masing regulasi tersebut.
- Jelaskan perbedaan antara ISO 27001 dan PCI-DSS dari sisi: (a) siapa yang wajib memenuhi, (b) apa yang diatur, dan (c) konsekuensi jika tidak dipenuhi.
- Sebuah rumah sakit swasta mengalami kebocoran data rekam medis 10.000 pasien. Dari perspektif UU PDP dan HIPAA, apa saja kewajiban notifikasi yang harus dilakukan dan dalam waktu berapa lama?
- Mengapa prinsip 'Accountability' dalam GDPR dan 'Privacy by Design' dianggap merupakan pendekatan yang lebih proaktif dibanding regulasi perlindungan data sebelumnya?
- Dalam gap analysis ISO 27001 perusahaan Anda, ditemukan bahwa password karyawan tidak pernah di-hash dan disimpan dalam plaintext di database. Kontrol Annex A mana yang dilanggar? Apa rekomendasi remediasi prioritas tingginya?

Tugas Kelompok — Analisis Kepatuhan

 TUGAS	Studi kasus: Platform kesehatan digital Indonesia (seperti telemedicine) yang memiliki pengguna di Indonesia dan berencana ekspansi ke Singapura dan UE. Tugas kelompok (3–4 orang): 1. Identifikasi semua regulasi yang relevan dan wajib dipenuhi 2. Buat gap analysis terhadap minimal 10 kontrol ISO 27001 Annex A (pilih kontrol yang paling relevan untuk platform kesehatan digital) 3. Analisis kewajiban khusus UU PDP untuk data kesehatan (data pribadi spesifik) 4. Identifikasi apakah HIPAA berlaku dalam skenario ekspansi ini dan mengapa 5. Buat roadmap compliance 12 bulan: prioritaskan perbaikan berdasarkan risiko dan urgensi regulasi Format: Presentasi 15 menit + dokumen laporan (maks. 8 halaman). Dikumpulkan: Pertemuan 13.
---	--

M. Referensi & Bacaan Lanjutan

- ISO/IEC 27001:2022 — Information Security Management Systems: Requirements
- ISO/IEC 27002:2022 — Information Security Controls (panduan implementasi Annex A)
- GDPR Full Text: gdpr-info.eu (versi bahasa Inggris resmi yang mudah dibaca)
- UU No. 27 Tahun 2022 tentang Perlindungan Data Pribadi — peraturan.go.id
- PCI DSS v4.0 Requirements: pcisecuritystandards.org/document_library
- NIST Cybersecurity Framework (CSF) 2.0: csrc.nist.gov/pubs/cswp/29
- ENISA: Guidelines on Personal Data Breach Notification — enisa.europa.eu
- BSI: Lembaga Sertifikasi ISO 27001 di Indonesia — bsi-indonesia.com
- KOMINFO: Panduan Implementasi UU PDP — kominfo.go.id